Conceptos básicos

© **Universidad de Palermo** | Prohibida la reproducción total o parcial de imágenes y textos.

Introducción

La finalidad que tiene un Penetration Test es identificar de forma temprana vulnerabilidades que podrían ser aprovechadas por un atacante.



Fuente: https://stock.adobe.com/ar/

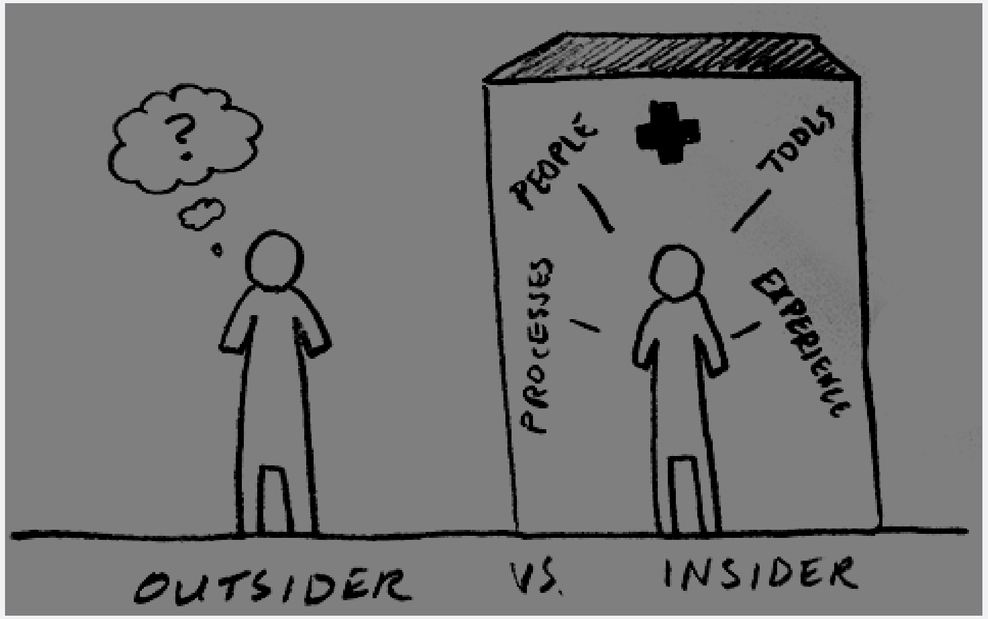
Definición

El Penetration Test es un proceso en el que se realizan pruebas sobre sistemas informáticos de la misma forma que podría hacerlas una persona malintencionada, pero con la diferencia de que se hacen bajo el consentimiento de la organización 'víctima', con el propósito de conocer las debilidades de su infraestructura, a fin de poder solucionarlas antes de que una persona malintencionada pudiera aprovecharse de ellas.

UP Universidad de Palermo ©

Amenazas

Existen distintos tipos de amenazas que pueden tener interés en atacar nuestros sistemas. Entre ellas podemos tener amenazas externas y/o internas.



Fuente: https://rochemamabolo.com

Amenazas externas

Amenazas externas

Entre las **amenazas externas** encontramos:

- Crimen organizado
- Terrorismo
- Gobiernos
- Competidores
- Hacktivistas
- Otro tipo de atacantes



Fuente: https://www.freepik.es/

Amenazas internas

Amenazas internas

Entre las amenazas internas encontramos:

- Empleados despistados
- Empleados descontentos
- Administradores despistados
- Administradores descontentos
- Clientes
- Proveedores



Fuente: https://www.freepik.es/

Distintos niveles de atacantes

Los atacantes pueden tener distintos niveles de conocimiento sobre cómo atacar los sistemas informáticos.

Entre ellos encontramos los siguientes:

- Script kiddies
- Nivel intermedio
- Nivel elevado
- Investigadores de seguridad
- Atacantes de elite

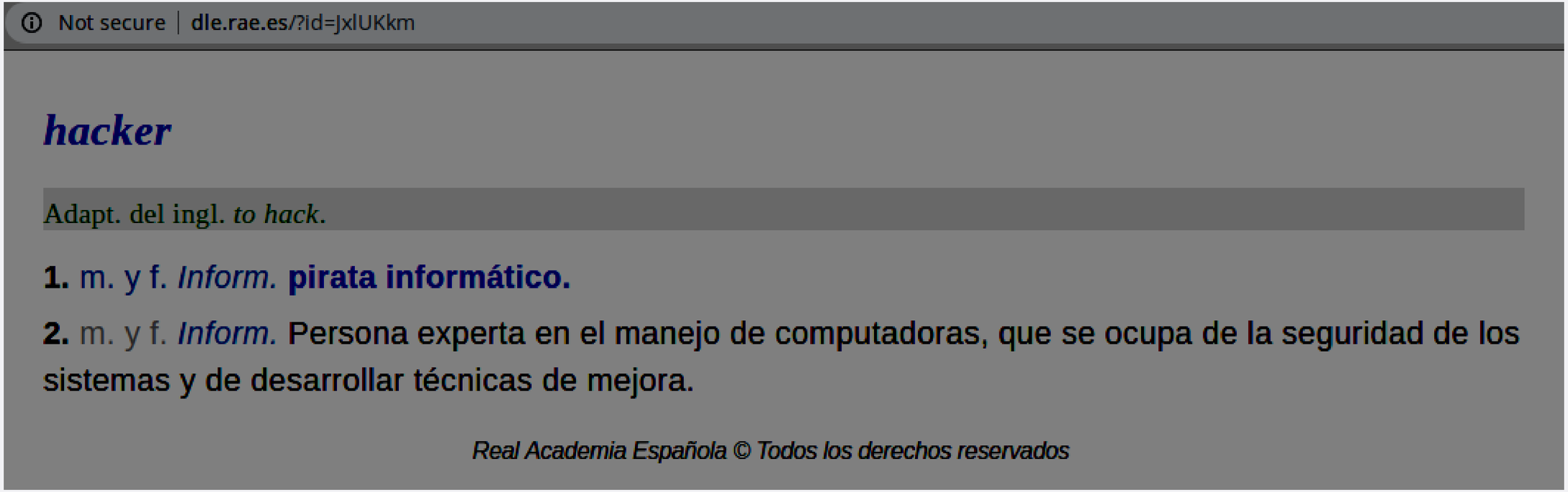


Fuente: https://www.freepik.es/

UP Universidad de Palermo ©

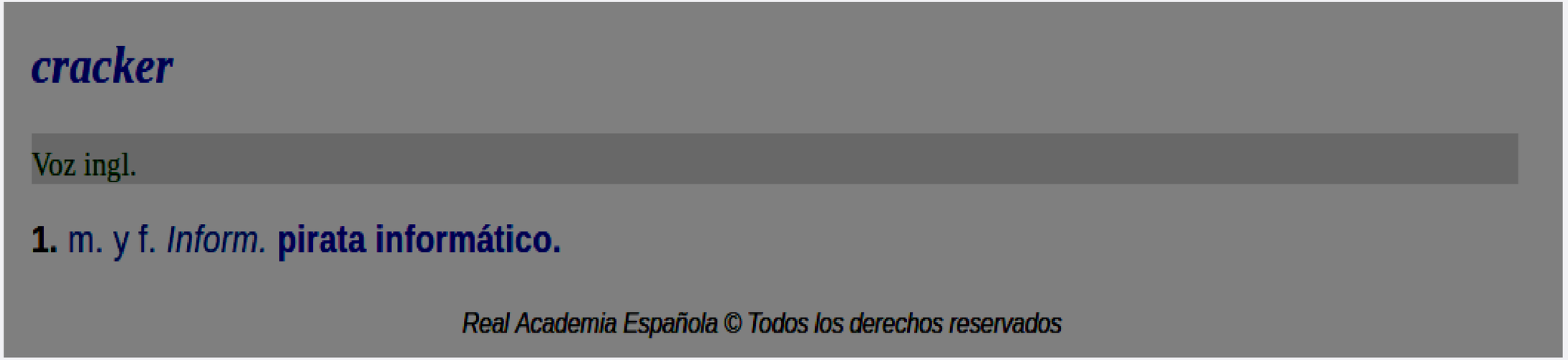
Hackers, crackers y distintos sombreros

Hackers, Crackers y distintos sombreros



Fuente: Definición de hacker [captura de pantalla]

Hackers, crackers y distintos sombreros



cracker

Voz ingl.

1. m. y f. *Inform.* **pirata informático.**

Real Academia Española © Todos los derechos reservados

Fuente: Definición de cracker [captura de pantalla]

Hackers, crackers y distintos sombreros

Con respecto a los sombreros, podemos identificar los siguientes:

- **Black Hat:** atacante malicioso quien, a partir de sus conocimientos, trata de romper la seguridad de los sistemas.
- **White Hat:** experto en Ciberseguridad que intenta mejorar la seguridad de los sistemas, encontrando vulnerabilidades y corrigiendo las mismas.
- **Grey Hat:** experto en Ciberseguridad que trabaja en ambos lados.



Fuente: https://esgeeks.com/tipos-hackers-y-sombreros/

UP Universidad de Palermo ©

Distintos tipos de pentest

Al igual que con los sombreros, los tipos de pentest se clasifican por colores, pero en este caso son Cajas.

- **Blackbox:** la finalidad que tiene este tipo de análisis es pararse como lo haría un atacante externo sin disponer de conocimientos sobre las tecnologías existentes e ir aprendiendo sobre la infraestructuras, reconociendo vulnerabilidades y explotándolas.
- **Greybox:** en este caso, se plantea un escenario de un usuario con pocos privilegios y la finalidad es tratar de conseguir escalar en privilegios.
- **Whitebox:** el último escenario es identificar vulnerabilidades desde adentro, suponiendo que pudiesen existir backdoors, tanto del lado del código como de la configuración de la infraestructura.

UP Universidad de Palermo ©

Pentest Blackbox

El pentester dispondrá únicamente de la/s URL/s o la/s IP/s que deba analizar.

Irá descubriendo la infraestructura a medida que se vayan escaneando los objetivos.

Una vez descubiertas los servicios, se irán descubriendo vulnerabilidades y a partir de allí se irán explotando las mismas con el fin de cumplir con el objetivo del proyecto.

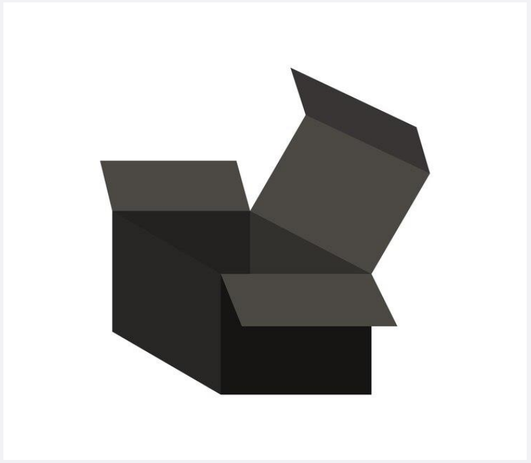


Fuente: https://www.freepik.es/

Pentest Greybox

Simulando ser un usuario disconforme de la organización se tratará de identificar vulnerabilidades.

A partir de dichas vulnerabilidades se intentará escalar en privilegios con el fin de tomar control sobre la infraestructura.



Fuente: https://www.freepik.es/

UP Universidad de Palermo ©

Pentest Whitebox

En este tipo de análisis se plantea el acceder a la información no solo desde el exterior del entorno del sistema objetivo, sino que también se analizará tanto desde el código fuente del mismo como la configuración de la infraestructura que soporta.

De este modo se podrá testear la aplicación en mayor profundidad recolectando mayor cantidad de vulnerabilidades en el entorno.



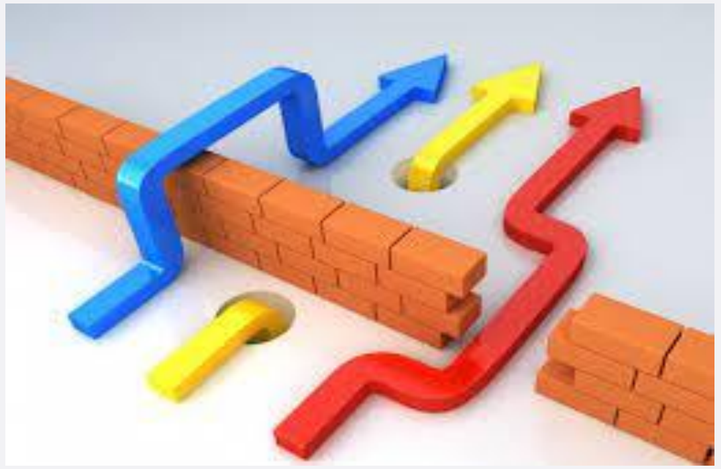
Fuente: https://www.freepik.es/

UP Universidad de Palermo ©

Pentest vs VA

Dentro de un análisis de vulnerabilidades o VA se analizarán todas las vulnerabilidades que disponga el entorno a testear.

Este tipo de análisis permite identificar el abanico de vulnerabilidades que podrían ser aprovechados por un atacante real.



Fuente: https://www.incibe.es/

Consideración inicial

Otro punto de suma importancia es que, antes de realizar las pruebas, el profesional debe conseguir un permiso explícito de la organización, autorizándolo a comprobar la existencia de vulnerabilidades.

También se debe aclarar cuáles son las pruebas que van a ser realizadas y cuáles quedarán afuera del proyecto.

Esto es debido a que, generalmente, existen pruebas que podrían llegar a producir un impacto negativo en la operatoria de los sistemas e, incluso, dejarlos fuera de funcionamiento.

UP Universidad de Palermo ©

9 pasos

Se pueden definir nueve pasos para completar adecuadamente el proceso:

1. La organización desea saber si sus sistemas son realmente seguros.
2. Selecciona y contrata un servicio profesional de ethical hacking.
3. Lo autoriza a realizar el trabajo mediante diversas pautas.
4. Planifican estratégicamente cómo se realizará y el alcance que tendrá.
5. Se realizan las tareas imitando al atacante, pero sin comprometer datos.
6. Luego, analiza los resultados del security assessment.
7. Confecciona un reporte detallado para que la organización lo evalúe.
8. Soluciona lo vulnerable o mitiga lo potencial para dejar el sistema más seguro.
9. Se adoptan políticas de control y seguimiento (normativa).

UP Universidad de Palermo ©

Fases del proceso

El proceso de pentest se divide en etapas, en las que cada una se encarga de un objetivo puntual, las cuales son:

- Reconocimiento
- Enumeración
- Ganar acceso
- Mantener acceso
- Borrar rastros.



Fuente: https://www.linkedin.com

Fases reales de un pentest

- Acuerdo de confidencialidad
- Reconocimiento
- Enumeración
- Ganar acceso /Explotación
- Mantener acceso
- Borrar rastros.
- Informes

UP Universidad de Palermo ©

Acuerdo de confidencialidad o NDA

Un NDA, acuerdo de confidencialidad, acuerdo de no divulgación, también referidos como contratos o convenios de confidencialidad, es un contrato legal entre al menos dos entidades para compartir material confidencial o conocimiento para ciertos propósitos, pero restringiendo su uso público.

El NDA se firma habitualmente cuando dos empresas o individuos acuerdan alguna relación comercial y necesitan entender los procesos usados en la otra compañía con el propósito de evaluar el interés de esta.

UP Universidad de Palermo ©

Reconocimiento

En esta etapa vamos a conseguir toda la información posible acerca de nuestro objetivo, pero sin realizar ningún tipo de ataque ni comportamiento propio de actividades malintencionadas.

Para esto, vamos a consultar bases de datos públicas (de libre acceso) y herramientas estándar que cualquiera podría utilizar para propósitos totalmente benignos.

Gracias a esto podremos obtener información como: sitios web de la organización, direcciones de correo electrónico, teléfonos, nombres de empleados y sus cargos, dirección física de la empresa (y de sus sucursales, si las tiene), etc.

UP Universidad de Palermo ©

Reconocimiento

En esta fase también se reconocerá el campo de trabajo sobre el cual se encuentra inmerso el objetivo.

Entre algunas de las técnicas utilizadas dentro de esta fase se encuentran las siguientes:

- Buscadores web
- Google Hacking
- Shodan
- Base de datos Whois
- Consultas DNS
- Ingeniería social
- Redes sociales
- Dumpster Diving
- Información dentro de los correos electrónicos

UP Universidad de Palermo ©

Enumeración

A la fase de enumeración también se la conoce como un reconocimiento activo. En esta fase empezaremos a utilizar herramientas que analizarán nuestro objetivo profundamente.

Dependerá de la labor a realizar, ya que tenemos herramientas para analizar infraestructura, aplicaciones web, escaneadores de vulnerabilidades, clonadores de sitios web, técnicas para acceder a información de un usuario por medio de correos electrónicos, entre otros.

UP Universidad de Palermo ©

Enumeración

En esta segunda etapa pasamos a utilizar herramientas que podrían llegar a generar un cierto grado de sospecha si la organización analizada cuenta con sistemas de detección y prevención de intrusos y/o se hace un buen análisis de los registros (logs) de sus sistemas.

Algunas de las herramientas más populares que vamos a utilizar son los escaneadores de puertos (como nmap) y los analizadores de vulnerabilidades (como Nessus y OpenVas).

Gracias a esto, vamos a poder descubrir la presencia de software vulnerable y distintas posibilidades para explotar esas vulnerabilidades (pero, aún, sin explotarlas, porque eso queda para la siguiente etapa).

UP Universidad de Palermo ©

Ganar acceso/Explotación

- En esta etapa es cuando vamos a realizar el “ataque” propiamente dicho.
- Generalmente, utilizando algún exploit, abusaremos de software mal configurado o desactualizado para tomar el control de los sistemas de la organización.
- En esta etapa también se deben demostrar las distintas posibilidades de Denegación de Servicio (DoS) que podríamos llegar a generar.
- Una vez hecho esto, lo ideal sería que contemos con la capacidad de controlar alguno de los sistemas remotos o, en el peor de los casos, tener la capacidad de dejarlos sin funcionamiento (DoS).

UP Universidad de Palermo ©

Ganar acceso/Explotación

A partir de las vulnerabilidades descubiertas en la fase anterior, tendremos que dedicarle un tiempo a la investigación de las herramientas y técnicas para explotar las mismas.

Una vez encontrado y/o desarrollado el exploit correspondiente, procederemos a explotar las vulnerabilidades.

Algunos repositorios:

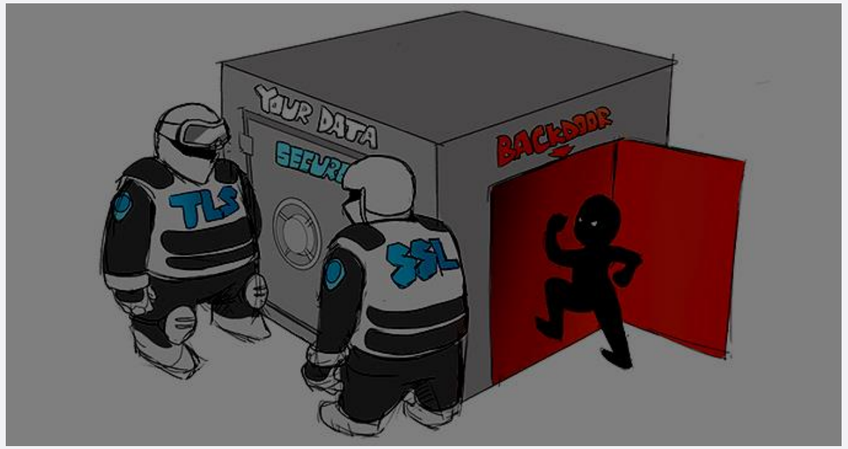
- www.packetstormsecurity.org
- www.exploit-db.com
- Metasploit

UP Universidad de Palermo ©

Mantener acceso/ Post Explotación

Una vez que conseguimos explotar la vulnerabilidad, el siguiente paso será lograr mantener persistencia. Para ellos podemos migrar de proceso, dejar un backdoor, un troyano o un rootkit.

Lo más usual es utilizar un Backdoor, el cual nos permitirá mantener el acceso contra la máquina víctima por medio de un método alternativo.



Fuente: https://felastory.com

Mantener acceso/ Post Explotación

En esta etapa simplemente nos vamos a asegurar de que el acceso que ganamos en la etapa anterior sea mantenido.

Es decir que, aunque la organización corrija los problemas que nos dieron acceso, nosotros deberíamos poder seguir teniendo el control de los sistemas.

Esto se hace, principalmente, instalando una puerta trasera (backdoor) que nos permita volver a ingresar al sistema a través de un canal no convencional.

En el caso de un sistema que cuente con una gran cantidad de usuario autorizados, podríamos generar un usuario adicional, intentando que no sea descubierto por los administradores.

UP Universidad de Palermo ©

Post Explotación

Otra acción común dentro de la fase de Post Explotación es el borrado de rastros, tiene como finalidad establecer cómo dentro de una organización pueden responder ante un incidente, cómo pueden trabajar aplicando Informática Forense si los registros fueron borrados o modificados.



Fuente: https://images.app.goo.gl/ns7CvsQSANdhQxhf6

Informe

Como última fase tenemos la generación del informe.

El mismo debe tener el contenido adecuado para su destinatarios. ¿Qué quiere decir esto? Tiene que ver con el lenguaje que utilizaremos en cada reporte.

Suelen realizarse 2 (dos) informes finales:

- Ejecutivo.
- Técnico.

UP Universidad de Palermo ©

Informe ejecutivo

En el **informe ejecutivo** deben especificarse las tareas realizadas y una conclusión con respecto a los resultados obtenidos a partir del análisis realizado.

Debe ser claro y conciso, tratando de utilizar palabras no técnicas para que pueda ser comprendido por gente del negocio.

Algo que no debe faltar en este informe es el estado de situación del objetivo analizado y gráficos que simplifiquen su entendimiento.

UP Universidad de Palermo ©

Informe ejecutivo

Informe ejecutivo

- Carátula
- Índice
- Objetivo
- Alcance
- Línea de tiempo
- Explicación del ataque
- Resumen ejecutivo
- Conclusión

UP Universidad de Palermo ©

Informe técnico

Por último tenemos el **informe técnico**. Este tendrá todo el contenido incluido en el informe ejecutivo sumando todo lo necesario como para que el área técnica de la organización comprenda las acciones realizadas durante el proceso.

Deberá indicar las herramientas utilizadas, todas las vulnerabilidades identificadas, los hosts donde fueron ubicadas, cuales fueron explotadas, CVEs asociados a cada vulnerabilidad junto con su respectiva criticidad de evidencias.

Tendrá que disponer de recomendaciones de mejora con el fin de mitigar todas las vulnerabilidades descubiertas.

UP Universidad de Palermo ©

Informe técnico

Informe técnico

A los ejes del informe ejecutivo **deben adicionarse al informe técnico** los siguientes puntos:

- Herramientas utilizadas
- Detalle de vulnerabilidades
- Nombre de vulnerabilidad
- Criticidad
- Descripción
- Impacto
- Recomendación
- Referencias
- Activo
- Evidencia

UP Universidad de Palermo ©



© Universidad de Palermo
Prohibida la reproducción total o parcial de imágenes y textos.